Acciones correctivas, preventivas y plan de mejoramiento

Proyecto: SaborExpress | **Fecha de corte:** 14 de octubre de 2026 | **Versión:** 2.0 | **Tipo:** Documento técnico y académico

Estado de la evidencia: inspección documental y estática del código. Las pruebas de ejecución y los datos institucionales no aportados no se presumen realizados.

1. Criterio de evaluación

Se clasifican riesgos observables en diseño/código y brechas de evidencia. Se habla de **recomendaciones de corrección**, no de vulnerabilidades explotadas o incidentes reales, porque no se ejecutaron pruebas de seguridad ni explotación.

2. Registro de acciones

ID

Hallazgo/riesgo

Acción

Prioridad

Responsable sugerido

Método

Cierre

AC-01

README Docs identificaba Supabase como backend

Corregir stack actual .NET

Alta

Documentación

Actualizar descripción y validarla contra csproj

README consistente

AC-02

Archivos vacíos de documentación

Reemplazarlos por contenido real

Alta

Documentación

Revisar formatos y todos los tamaños > 0

Inventario completo

AC-03

Apertura de CORS a rangos de dev

Restricción por entorno

Alta

Backend/DevOps

Validar AllowedOrigins productivos

Test orígenes

AC-04

Migración automática en arranque

Revisión estrategia de liberación

Alta

Backend/DBA

Separar migration job

Despliegue controlado

AC-05

Webhook con cuerpo en log

Minimización y redacción de logs

Alta

Backend

Revisar PaymentController

Sin datos sensibles

AC-06

Autorización por roles/objetos sin batería

Pruebas negativas intersede

Crítica

QA

Diseñar permisos sobre ID de recurso

Matriz de denegación

AC-07

Wompi sin evidencia de sandbox

Ensayar firma, duplicados y rechazo

Crítica

Backend/QA

Pruebas webhook

Evidencia idempotencia

AC-08

DB multi-proveedor no demostrada

Elegir motor y certificar migraciones

Alta

DBA

Integración motor seleccionado

Esquema validado

AC-09

README web/móvil de plantilla

Personalizar onboarding

Media

Frontend

Documentar navegación y env

Manual actualizado

AP-10

Falta repositorio visible de tests

Implementar CI y tests

Alta

QA/DevOps

Test suites + pipeline

Reporte verificado

AP-11

Diseño sin respaldo auditado

Backup/restore programado

Alta

DevOps

Ensayo desechable

Restauración aprobada

AP-12

Resultados de usabilidad ausentes

Sesiones éticas voluntarias

Media

UX

Protocolo con consentimiento

Resultados reproducibles

3. Priorización y seguimiento

Prioridad crítica: riesgos de doble cobro, autorización indebida y pérdida de integridad. Alta: configuración de producción y trazabilidad documental. Media: mejoras de UX y manuales. Cada

hallazgo deberá asignarse, estimarse, revisarse en PR y cerrarse con una prueba. Las áreas asignadas son roles sugeridos, no personas designadas.

4. Lecciones y prevención

Documentar decisiones arquitectónicas por SHA; automatizar validación del inventario de rutas; usar un único catálogo de API exportado de Swagger; integrar tests de regresión para pagos y roles; mantener manuales sincronizados con cada release; revisar cambios de esquema por proveedor antes de publicar.

Fuentes primarias de implementación

API: https://github.com/yersonct/SaborExpressBack/tree/main

Web: https://github.com/yersonct/SaborExpressWeb/tree/main

Móvil: https://github.com/yersonct/SaborExpressMovil/tree/main

Referencia de presentación: https://github.com/jsgh1/SRD-v1/tree/dev/docs/docs-SRD

Control documental: documento elaborado a partir del estado observado en octubre de 2026. Antes de entregar, verificar el commit exacto, responsable, revisión del instructor y cualquier cambio posterior del código.